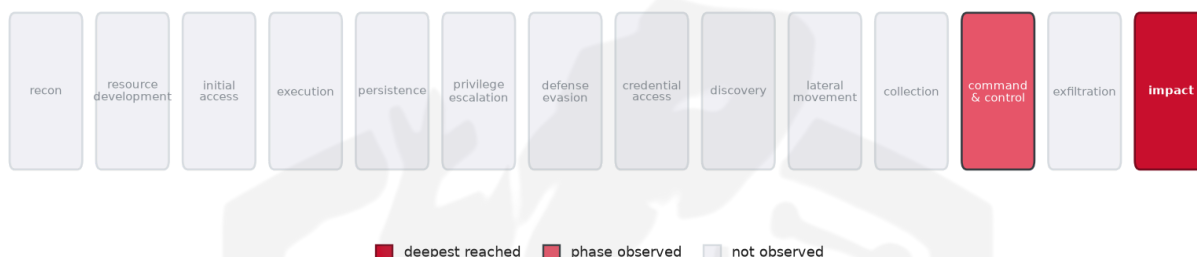


# THREAT REPORT: APT28 LEVERAGES OPEN DIRECTORY TO DISTRIBUTE MOOBOT AND MIRAI

## Visual Summary

### Kill-Chain Reach — Critical (deepest phase reached: impact)



How far down the attack chain this campaign reached; deepest phase in crimson.

### Defensive Chokepoint — why this control is the priority



The control that most disrupts the attack (priority in crimson).

## Summary

The source attributes recent activity to APT28, which has exposed Moobot source code via an open directory and is observed delivering both Moobot and Mirai malware. The campaign appears to target entities in China, though no specific vulnerability has been identified. Analysts note the use of ingress tool transfer techniques to move payloads. Priority should be given to enforcing egress filtering and blocking or alerting on downloads performed with certutil, bitsadmin, or curl, as well as inspecting inbound tooling through proxies.

## Threat Overview

APT28 is linked to the distribution of the Moobot and Mirai malware families. No concrete CVE is cited in the source material, indicating that the exploitation does not rely on a known vulnerability. The observed

activity is directed at victims located in China.

## Attack Chain and Priority Control

---

The reporting indicates that the adversary first obtains access to an openly accessible directory, then uses **T1105 – Ingress Tool Transfer** to download additional tooling and malware onto compromised hosts. The priority control recommended is: **Enforce egress filtering; block/alert on certutil/bitsadmin/curl downloads; proxy-inspect inbound tooling.**

## Infrastructure and Corroboration

---

Third-party enrichment shows that the command-and-control infrastructure is hosted by China Mobile Communications Corporation, Matteo Martelloni Trading as DELUXHOST, and GTT Communications Inc. Abuse.ch corroborates the presence of the Mirai malware family on the same infrastructure. No indicators reached the high-confidence threshold on AbuselPDB.

## Technical Appendix

---

*Ground-truth telemetry from the source pulse; analytical scores are secondary and clearly labelled.*

### Observed Techniques (ATT&CK, machine-extracted from report text — reduced confidence)

*The source pulse carried no expert ATT&CK tags, so these techniques were inferred from its narrative by a self-consensus LLM extractor and validated against the ATT&CK catalogue. Treat this technique set, and the chokepoint, kill-chain and risk scores derived from it, as lower-confidence than an expert-tagged brief. - T1105 Ingress Tool Transfer - T1498 Network Denial of Service*

### Analytical Scores

- Priority technique (graph chokepoint): T1105 Ingress Tool Transfer (centrality 0.7071).
- Operational risk: Critical (score 0.792, reaches impact).

### Behavioral Signature Cluster

- Method: technique-overlap cosine vs 170 MITRE ATT&CK Groups (top overlap 0.2673; reference threshold  $\tau = 0.6$ ).
- These are behavioural resemblances for defensive playbook cross-referencing, not an identity assessment. Where the source pulse names an actor, that attribution is authoritative; the overlaps below neither confirm nor contest it.

Nearest historical profiles by behavioural overlap (resemblance only):

| Historical Profile | Behavioural Overlap |
|--------------------|---------------------|
| Volatile Cedar     | 0.2673              |
| Winnti Group       | 0.25                |
| Ajax Security Team | 0.2236              |
| Nomadic Octopus    | 0.2132              |
| Elderwood          | 0.2041              |

## Enrichment Signal

- Highest AbuseIPDB confidence among IOCs: 0%.
- Malware families corroborated by abuse.ch: Mirai.
- Note: enrichment raises the severity signal (an IOC at or above 80% AbuseIPDB confidence, or a confirmed malware-family hit). This is context, not a change to the source assessment.

## Indicators of Compromise (defanged — non-clickable)

The network and file indicators observed in this activity are listed below for blocklisting:

| Type   | Indicator            | Context                                                                     |
|--------|----------------------|-----------------------------------------------------------------------------|
| IP     | 162[.]141[.]92[.]192 | AbuseIPDB 0% (NL) · Mirai · AS214677 Matteo Martelloni Trading As DELUXHOST |
| IP     | 112[.]21[.]241[.]27  | AbuseIPDB 0% (CN) · AS56046 China Mobile Communications Corporation         |
| IP     | 39[.]175[.]139[.]108 | AbuseIPDB 0% (CN) · AS56041 China Mobile Communications Corporation         |
| IP     | 86[.]53[.]111[.]212  | AbuseIPDB 0% (DE) · AS3257 GTT Communications Inc.                          |
| Domain | api[.]cemg[.]xyz     |                                                                             |

Reputation by AbuseIPDB · malware attribution by abuse.ch · Geo/ASN data by IP2Location LITE.

## Flame Cell // Adversary Pivot [ BETA ]

*BETA. A hypothetical tabletop projection, anchored to documented ATT&CK behaviour and technique co-occurrence across 170 tracked groups. It is not a prediction; treat it as a war-game prompt and review before acting. Spot a pivot that looks wrong? [norbert@salacti.com](mailto:norbert@salacti.com)*

- **Control applied:** T1105 Ingress Tool Transfer (command-and-control)

- **Observed here:** T1105 Ingress Tool Transfer was the command-and-control control point here; the pivot is drawn from APT28's own documented ATT&CK repertoire.
- **Projected pivot:** T1071 Application Layer Protocol (command-and-control)
- **Basis:** documented in APT28's own ATT&CK repertoire, and disproportionately paired with Ingress Tool Transfer across tracked groups (lift 1.5, ~1.5x base rate). Their move, not a generic one.

If the ingress tool transfer via T1105 is blocked, the adversary could pivot to using Application Layer Protocol (T1071) by encapsulating malicious payloads and command-and-control traffic within legitimate HTTPS or DNS requests, thereby leveraging trusted web services to continue staging and communicating with compromised hosts. Defenders should implement an egress filter to known-good destinations, inspect DNS/TLS for beaconing, and alert on anomalous outbound patterns.

**Also plausible (same tactic):** T1102 Web Service (n=25, lift 1.5), T1573 Encrypted Channel (n=18, lift 1.3)

#### Detection and hardening for the pivot (T1071 Application Layer Protocol)

- **Telemetry:** Proxy / DNS logs; Network flow / TLS metadata
- **Detect:**
  - Beaconing: regular-interval, low-jitter connections to rare destinations
  - HTTP(S) to newly registered or low-reputation domains; odd user-agents
  - DNS with high entropy or excessive TXT-record query volume
- **Harden:**
  - Force egress through an inspecting proxy; block direct outbound
  - TLS inspection where lawful; DNS filtering and logging
- **MITRE:** M1031 Network Intrusion Prevention, M1037 Filter Network Traffic · DS0029 Network Traffic